
EARNING THE RIGHT TO ACT: EPISTEMIC CONTROL LOOPS FOR TRUSTWORTHY AGENTIC SECURITY OPERATIONS

A PREPRINT

Drupad H. Sachania
Independent Researcher
Bengaluru, India
drupad.h.sachania@live.com

Version 2 — October 2026 (Version 1: April 2026)

*“The question is not whether an LLM can generate a hypothesis.
The question is whether the system knows when not to believe it.”*

ABSTRACT

Security Operations Centers (SOCs) are adopting agentic AI faster than they are learning to govern it. The 2026 SANS SOC Survey finds that 79% of SOCs use AI or machine learning, but only 36% have integrated it into defined workflows [55]. Meanwhile, the failure modes of agentic systems have moved from the laboratory into production. Between mid-2025 and late 2026, zero-click prompt injection against Microsoft 365 Copilot (CVE-2025-32711) [51], data exfiltration from Salesforce Agentforce [43], a systemic command-injection flaw affecting the Model Context Protocol (MCP) ecosystem [47], and in-the-wild exploitation of AI gateways [64] showed the same root cause: agents that treat untrusted context as instructions and act on it with unearned confidence. Frontier models remain poorly calibrated. On the current Humanity’s Last Exam leaderboard, most frontier models show RMS calibration error between 38% and 57% [56].

This paper argues that the central problem is insufficient *epistemic control*, not insufficient automation, and presents an Epistemic Decision Quality Framework for SOCs. The framework embeds measurable controls in an Observe–Orient–Decide–Act loop: (1) zero-trust ingestion with provenance labelling and taint tracking, so that untrusted telemetry can inform hypotheses but never authorise actions; (2) large language models (LLMs) restricted to generating competing, MITRE ATT&CK-grounded hypotheses, supported by corrective and active retrieval; (3) a triple decision gate combining structural simulation against topology and identity graphs, per-decision confidence calibrated against a population-level certification target, and trajectory-level uncertainty propagation; and (4) bounded outcomes (ACT, DEFER, ESCALATE) routed by action risk tier, with signed capability tokens and a tamper-evident audit trail aligned with ISO/IEC 42001 and the NIST AI RMF.

Version 2 corrects several statistics and citations from Version 1, separates population-level calibration from per-decision uncertainty, maps the framework to the OWASP Top 10 for Agentic Applications, analyses documented 2025–2026 incidents against its controls, and reports the proof-of-concept results as preliminary, together with a full evaluation protocol. In a small proof-of-concept on static, synthetic SOC scenarios, the framework reduced analyst-labelled hallucinated reasoning from 12% to 3% against an unconstrained baseline, at the cost of raising the deferral rate from 5% to 22%. We argue that security AI should be designed for decision integrity under uncertainty rather than for speed and confidence.

Keywords Agentic AI Security · SOC Automation · Uncertainty Quantification · Calibration · Prompt Injection · Human-in-the-Loop AI · OWASP Agentic Top 10 · Model Context Protocol · ISO/IEC 42001

1 Introduction

Modern SOC operations operate where machine-speed threats meet human cognitive limits. Their architecture has moved from manual triage, through Security Orchestration, Automation and Response (SOAR) playbooks, to agentic LLM-based systems that correlate alerts, enrich context, and recommend or execute containment [53]. The pressure behind this move is real. The 2025 ISC2 Cybersecurity Workforce Study, which surveyed 16,029 practitioners, found that 59% of respondents face critical or significant skills gaps (up from 44% in 2024). Of those surveyed, 88% had experienced at least one significant security consequence because of a skills shortage, and 69% had experienced more than one [25]. Notably, ISC2 stopped publishing a single headcount gap in 2025 because respondents reported that skills, not headcount, were the binding constraint. The widely quoted 4.8 million gap is the 2024 estimate [24]. On the adversary side, the Verizon 2026 Data Breach Investigations Report found that vulnerability exploitation overtook credential abuse as the leading initial-access vector, at 31% of breaches. In a joint analysis with Anthropic’s Safeguards team, the median threat actor applied AI across 15 ATT&CK techniques [62]. Automated traffic is also growing fast. HUMAN Security reports that AI-driven traffic grew 187% in 2025 and agentic traffic grew 7,851% year over year, although agentic traffic was still only 1.7% of AI traffic at year end [22].

Governance has not kept pace with deployment. In the 2026 SANS SOC Survey, 79% of SOC operators reported using AI or machine learning, but only 36% had integrated it into defined workflows [55]. In the 2026 SANS AI Survey, active use rose from 50% to 78% in a year, while the share of respondents reporting significant AI shortcomings in detection and response rose from 45% to 63%. Respondents’ top concerns were transparency and trust in AI decisions (40%) and hallucinations (34%) [54]. IBM’s 2026 Cost of a Data Breach study reports that 92% of organisations that suffered an AI-related breach lacked proper AI access controls [23].

The underlying models give good reason for caution. On Humanity’s Last Exam (HLE) [49], most frontier models report RMS calibration error between 38% and 57% [56] (Section 2.3). Two mechanisms make this miscalibration operationally dangerous. First, common training and evaluation regimes reward confident guessing over acknowledging uncertainty, which produces fluent, assertive errors [29]. Second, people systematically overestimate how much an LLM knows when its explanations sound authoritative [59]. This feeds automation bias [48] and what we call *narrative hardening*: the first AI-generated hypothesis becomes the organisation’s working truth, and contradictory evidence stops being sought. The 2025 OWASP Top 10 for LLM Applications treats this overreliance under LLM09 (Misinformation) [46]. The OWASP Top 10 for Agentic Applications adds Human-Agent Trust Exploitation (ASI09) and Cascading Failures (ASI08) as distinct risks [45].

Thesis. The core challenge is not insufficient automation but insufficient *epistemic control*: a system’s ability to know, measure and act on what it does not know.

Contributions. This paper makes five contributions:

1. An OODA-structured *epistemic control loop* for SOC automation. In it, LLMs only generate hypotheses, and authority to act is earned through explicit gates (Section 4).
2. A *two-level uncertainty design*. Population-level calibration certification (ECE, Brier score) is kept separate from per-decision gating on calibrated confidence and on trajectory-level propagated uncertainty (Section 4.3).
3. A *risk-tiered action model* with signed capability tokens and a taint veto, so that confidence can never override untrusted provenance (Section 4.2).
4. An *incident-grounded threat analysis* that maps documented 2025–2026 agentic incidents and the OWASP Agentic Top 10 to framework controls, including residual gaps (Section 3).
5. *Preliminary* proof-of-concept results and a full evaluation protocol for independent validation (Sections 5 and 6).

2 Background and Related Work

2.1 AI and Automation in Security Operations

AI in SOC workflows has gone through three generations: rule- and signature-based prioritisation; machine-learning anomaly detection combined with SOAR playbooks; and agentic LLM systems that reason over heterogeneous telemetry. The third generation introduces qualitatively new failure modes: hallucination cascades, calibration drift across model updates, narrative hardening, and inference-time manipulation of the agent itself [28]. AgentSOC [53] proposes a multi-layer architecture with three parts. A Narrative Counterfactual Engine (NCE) generates competing attack hypotheses. A Structural Simulation Engine (SSE) checks those hypotheses against network topology and identity privilege graphs. A risk-scoring module ranks candidate responses. Its authors describe the evaluation as a minimal

proof of concept on the LANL authentication dataset [53]. We adopt NCE- and SSE-style validation and add explicit uncertainty gating, adversarial-input controls and governance.

2.2 Retrieval-Augmented Generation for Security Investigations

Retrieval-augmented generation (RAG) [32] grounds generation in external evidence. Standard RAG, however, suffers from position effects in long contexts [33], brittle chunking, and single-shot retrieval that cannot resolve the multi-hop questions typical of incident investigation. Corrective RAG (CRAG) adds a retrieval evaluator that triggers corrective actions when retrieved evidence is weak [65]. Forward-Looking Active Retrieval (FLARE) triggers new retrieval when generation confidence falls [27]. Agentic RAG generalises both into planner-driven, multi-step retrieval [57]. In a SOC, the retrieval corpus (CTI, tickets, logs) is itself an attack surface, because memory and context poisoning is a first-class risk (ASI06) [45].

2.3 Calibration, Hallucination and Benchmark Reliability

Calibration. Table 1 reproduces the current HLE leaderboard, which reports accuracy alongside RMS calibration error [56]. (Version 1 of this paper mislabelled these figures as ECE and took them from the text-only board.) Accuracy has risen substantially since April 2026, but calibration error has mostly not improved. One model reaches 20%, which shows that good calibration is achievable but does not come automatically with capability.

Table 1: Humanity’s Last Exam (full, multimodal) leaderboard: accuracy and RMS calibration error. Model names are as listed by Scale. Accessed October 2026, after the September 2026 HLE-Rolling update [56]. Leaderboard values change over time.

Model (as listed)	Accuracy (%)	RMS calibration error (%)
GPT 6 Astra	54.80 $\pm$ 1.94	39
Fable 5.1 (xhigh)	46.50 $\pm$ 2.00	20
gemini-3.1-pro-preview (thinking high)	46.44 $\pm$ 1.96	51
Gemini 3.8 Flash	44.52 $\pm$ 1.96	51
gpt-5.4-pro-2026-03-05	44.32 $\pm$ 1.95	38
Muse Spark	40.56 $\pm$ 1.92	50
gemini-3-pro-preview	37.52 $\pm$ 1.90	57
gpt-5.4 (xhigh)	36.24 $\pm$ 1.88	42
claude-opus-4-7	36.20 $\pm$ 1.88	47
kimi-k2.5	24.37 $\pm$ 1.81	67

The benchmark is itself uncertain. Epoch AI audited a 48-question sample of HLE and found substantial, accuracy-altering errors in 46% of the sampled items [15]. FutureHouse estimated that $29 \pm 3.7\%$ of text-only chemistry and biology answers conflict with peer-reviewed literature [19]. HLE-Verified re-audited all 2,500 items: 668 were verified, 1,143 revised and 689 marked uncertain. On the revised items, model accuracy rose by roughly 30–40 percentage points, and the authors report a strong association between model confidence and item errors [66]. Calibration measured against noisy labels is therefore itself noisy. This motivates the label-quality requirements in our evaluation protocol (Section 6).

Hallucination. Version 1 cited aggregate hallucination rates (15–52%) and domain figures (up to 99% for code) taken from a secondary statistics site. We have removed them. Primary measurements are more modest but still matter operationally (Table 2). On Vectara’s HHEM leaderboard, which now uses a larger, non-public article set, grounded-summarisation hallucination rates for current frontier models range from low single digits to about 20% [61]. In code generation, 19.7% of 576,000 samples from 16 LLMs referenced non-existent packages, and 43% of hallucinated names recurred across all ten reruns of a prompt [58]. That repeatability makes “slopsquatting” practical. It also shows why single-model self-consistency is a weak hallucination detector: a model can be consistently wrong.

Table 2: Primary hallucination measurements relevant to SOC automation.

Setting	Measurement	SOC implication
Grounded summarisation (HHEM leaderboard) [61]	$\approx 3\text{--}20\%$ across frontier models	Misreading of CTI reports and case notes in RAG pipelines
Code generation: package references [58]	19.7% of samples; 43% of fabricated names repeat	Unsafe remediation scripts and dependency-confusion exposure
Expert QA with audited labels (HLE-Verified) [66]	+30–40 pp accuracy on corrected items	Measured error depends on ground-truth quality

2.4 Uncertainty Quantification for LLM Agents

Aleatoric uncertainty (irreducible noise in the data) and epistemic uncertainty (reducible ignorance in the model) call for different responses [30]. For deep ensembles, total predictive entropy decomposes into expected entropy (aleatoric) plus mutual information (epistemic) [12, 31]. This decomposition is useful, but it has known theoretical limitations [63]. For LLMs, semantic entropy computes uncertainty over clusters of meaning rather than over token strings [18]. Agentic settings bring new problems. Trajectory-level calibration (Holistic Trajectory Calibration) uses whole-trajectory features to calibrate agent success [67]. UProp splits the uncertainty of a decision into an intrinsic part and an extrinsic part inherited from earlier steps, and estimates the latter as mutual information [13]. SAUP weights step-level uncertainty by situational relevance [68]. RUPA propagates uncertainty over a directed graph of reasoning states, tool calls and observations [34]. In multi-agent pipelines, uncertainty can “vanish” at hand-offs: orchestrator and sub-agent uncertainty correlate only weakly even when the relayed content is fixed [14]. A recent position paper sets out open problems in agent uncertainty quantification [44].

2.5 Prompt Injection Defenses for Agents

In-band defenses (system-prompt hardening, delimiters, classifier filters) reduce but do not eliminate attack success. AgentDojo (97 tasks, 629 security cases) found that the best agents solve fewer than 66% of benign tasks, and that attacks succeed in under 25% of cases, falling to 8% when a detector is added [10]. Adaptive attackers break most published defenses: Nasr et al. [38] bypassed 12 recent defenses with attack success above 90% for most, although the defenses had originally reported near-zero success. A public red-teaming competition across 22 frontier agents produced more than 60,000 successful attacks out of 1.8 million attempts. Most agents violated policy within 10–100 queries, and robustness correlated only weakly with model capability [69]. Architectural defenses offer stronger guarantees. CaMeL separates control flow from data flow, so that untrusted data cannot change program flow, and enforces capability policies at tool-call time. It solves 77% of AgentDojo tasks with provable security, against 84% for an undefended system [11]. Design-pattern catalogues formalise similar constraints [3]. Meta’s “Agents Rule of Two” proposes that, until injection can be reliably detected, an agent should combine at most two of three properties: processing untrusted input, accessing sensitive systems or data, and changing state or communicating externally [36]. Our framework builds on this line of work. Its contribution is the *epistemic* layer (competing hypotheses, structural validation and calibrated deferral) placed on top of these security boundaries.

2.6 Identified Gap

Across SOC automation, RAG and agent security, uncertainty is still treated as a property of the model rather than as a measured control signal in the system. No existing SOC framework we are aware of combines: (i) provenance-aware ingestion; (ii) competing-hypothesis generation; (iii) structural validation; (iv) population-level calibration certification together with per-decision and trajectory-level gating; and (v) risk-tiered, auditable action authorisation.

3 Threat Model and the 2025–2026 Incident Landscape

3.1 Threat Model

Assets: production hosts, identities, network controls and data reachable through SOC response tools. **Adversary capabilities:** the adversary can (a) place arbitrary content in telemetry the SOC ingests (log fields, email bodies, file names, web-form inputs, CTI feeds); (b) compromise or impersonate third-party tools, plugins or MCP servers; and (c) adapt attacks to observed defenses [38]. The adversary *cannot* modify gate code, signing keys or the audit store. These

are protected by conventional controls. **Adversary goals:** induce harmful actions (isolating the wrong host, disabling an account, exfiltrating data); suppress true detections; or erode analyst trust. **Out of scope:** malicious insiders with key custody, poisoning of model weights, and compromise of the underlying cloud provider.

3.2 Documented Incidents

Table 3 summarises documented agentic incidents and maps each one to the control in this framework that addresses it. It also lists the residual gap, which these controls do not close by themselves.

Table 3: Documented agentic AI incidents (2025–2026) mapped to OWASP Agentic categories and framework controls.

Incident	Root cause	ASI	Framework control	Residual gap
EchoLeak, CVE-2025-32711, CVSS 9.3 [51]	Zero-click injection via email; bypassed classifier, link redaction and CSP via an allow-listed proxy	01	Untrusted provenance cannot authorise egress; taint veto	Rendering and egress paths must be controlled outside the LLM
ForcedLeak, CVSS 9.4 [43]	Injection via web-form field; exfiltration to an expired, re-registered allow-listed domain	01, 02	Taint tracking to communication sinks; signed capabilities	Allow-list hygiene (domain expiry)
MCP STUDIO command injection, 10 CVEs incl. CVE-2026-30615/-30623/-30624 [47]	Unvalidated <code>command/args</code> in MCP server configuration leads to RCE	04, 05	Tool allow-listing; LLM holds no tool authority	Supply-chain review of tool servers
Git MCP server, CVE-2025-68143/-68144/-68145 [9]	Path traversal and argument injection reachable via prompt injection	02, 05	Taint veto on execution sinks	Patch management
AI-gateway exploitation in the wild, CVE-2026-59822 + CVE-2026-42271 [64]	Authentication bypass chained with command injection; cryptominers; blind injection observed via out-of-band DNS	03, 05	Short-lived per-agent identities; sinks gated by provenance	Conventional exposure management
GTG-1002 AI-orchestrated intrusion campaign [2]	Agentic tooling executed most tactical work; operator’s agent also fabricated findings	—	Machine-speed DEFER/ESCALATE; adversary-agent claims treated as untrusted	Attribution contested; no public IOCs

Three lessons follow. First, every input-borne incident above succeeded because untrusted content was able to reach a *sink* (an egress channel, a shell, a tool configuration). Filters reduced the frequency of such attacks but never removed the path. Second, several were zero-click. A human-in-the-loop policy that applies only at the final action does not protect against exfiltration through rendering or retrieval side effects. Third, the GTG-1002 report notes that the attacker’s agent “frequently overstated findings and occasionally fabricated data” [2]. Independent researchers have questioned the report’s scope [4]. Either way, epistemic unreliability is a property of offensive agents too, and defenders should treat machine-generated claims, from either side, as hypotheses.

3.3 OWASP Agentic Top 10 Coverage

Table 4 maps the OWASP Top 10 for Agentic Applications [45] to framework mechanisms. The framework is designed primarily around ASI08 and ASI09, the epistemic risks that most product-level controls leave unaddressed. For the remaining categories it relies on established security engineering.

Table 4: OWASP Top 10 for Agentic Applications (2026) and corresponding framework mechanisms.

ID	Risk	Framework mechanism
ASI01	Agent Goal Hijack	Provenance labels and taint tracking; LLM has no tool authority; semantic firewall as a detector (defense in depth, not a boundary)
ASI02	Tool Misuse & Exploitation	Signed, scope-bound capability tokens; risk-tiered authorisation; dual-key approval for Tier 2
ASI03	Identity & Privilege Abuse	Short-lived, per-agent non-human identities; least agency
ASI04	Agentic Supply Chain	Allow-listed, pinned tool manifests; runtime behaviour monitoring
ASI05	Unexpected Code Execution	Sandboxed execution; taint veto on shell, query and egress sinks
ASI06	Memory & Context Poisoning	CRAG evaluator and FLARE retrieval; provenance of retrieved items; corpus integrity checks
ASI07	Insecure Inter-Agent Communication	Mutually authenticated, signed inter-agent messages; uncertainty carried across hand-offs
ASI08	Cascading Failures	Trajectory-level uncertainty gate (Gate 3); SSE invalidation returns to Orient
ASI09	Human-Agent Trust Exploitation	Calibrated confidence displayed with evidence gaps; DEFER as a legitimate outcome; dual-key overrides
ASI10	Rogue Agents	Bounded outcomes; tamper-evident audit trail; continuous monitoring

4 Methodology and Framework

4.1 Design Approach

We follow design science research [21]. System requirements are derived from two families of failure modes. *Cognitive* failures include narrative hardening, premature closure and automation bias [48, 50]. *Technical* failures include hallucination cascades, calibration drift and adversarial context injection. Because these failures are both social and technical, model-accuracy improvements alone cannot resolve them. They require architectural constraints that interrupt premature closure, together with procedures that make overriding those constraints deliberate and attributable. Throughout, we follow the principle of *least agency* [45]: an agent receives only as much freedom to act as its demonstrated reliability and the reversibility of the action justify.

4.2 Epistemic Control Loop

The framework puts Boyd’s Observe–Orient–Decide–Act loop into operation [5]. Each phase carries a measurable epistemic control (Figure 1). The governing principle is that *no AI-generated hypothesis reaches the Act phase without passing structural validation, a calibrated-confidence threshold, a trajectory-uncertainty threshold and a provenance check, all of which are evaluated outside the LLM.*

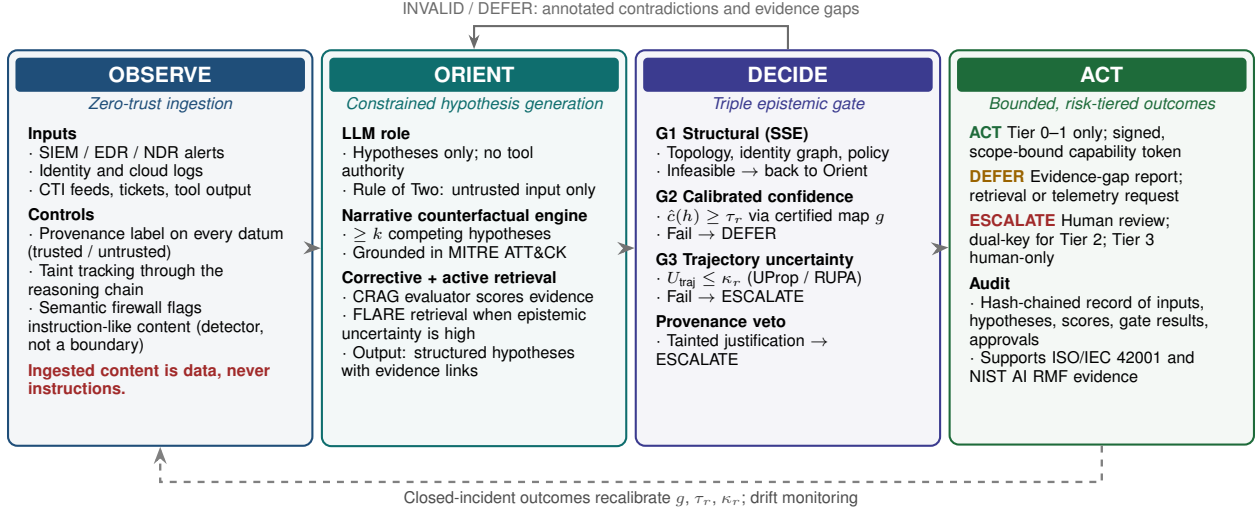


Figure 1: Epistemic control loop. Observe applies provenance labelling and taint tracking; Orient generates competing hypotheses with corrective and active retrieval; Decide applies three gates and a provenance veto outside the LLM; Act issues risk-tiered outcomes with signed capabilities and a tamper-evident audit trail. Outcomes from closed incidents feed recalibration.

Observe — Zero-Trust Ingestion

Alerts, SIEM logs, CTI and tool outputs are ingested under a zero-trust runtime model [28]. Every datum carries a provenance label: *trusted* (generated by authenticated internal systems with integrity protection) or *untrusted* (anything containing attacker-influenceable content, which in practice includes most log payloads). Taint propagates through retrieval, summarisation and hypothesis generation, so that each hypothesis and each proposed action records which untrusted inputs it depends on. A semantic firewall flags instruction-like content for analyst visibility. We treat it explicitly as a *detector*, not as a security boundary, because adaptive attacks reliably bypass classifiers [38]. The boundary is enforced in the Decide and Act phases.

Orient — Constrained Hypothesis Generation

The LLM receives untrusted input but holds no tool authority and cannot communicate externally. By construction it therefore satisfies the Rule of Two [36]. A Narrative Counterfactual Engine [53] produces at least k competing hypotheses grounded in ATT&CK techniques [60], including at least one benign explanation. This counters single-hypothesis anchoring. A CRAG evaluator scores retrieved evidence for relevance and consistency before generation [65]. FLARE-style retrieval is triggered when the epistemic component of uncertainty (Section 4.3) exceeds a threshold [27]. The output is a structured object for each hypothesis: the claimed techniques, the entities involved, links to supporting and contradicting evidence, missing evidence, and a proposed response with its risk tier.

Decide — Triple Epistemic Gate

Each candidate hypothesis h , with its proposed action a in risk tier r , is evaluated by deterministic code outside the LLM (Figure 2):

- Gate 1, structural feasibility (SSE)**. The hypothesised attack path is checked against the topology graph, identity and privilege graph, and policy constraints [53]. Hypotheses that require impossible reachability (for example, lateral movement into an air-gapped segment) or privileges that no implicated identity holds are marked INVALID and returned to Orient with the contradiction annotated. Gate 1 removes structurally impossible hypotheses. It cannot detect hypotheses that are feasible but false.
- Gate 2, calibrated confidence**. A raw uncertainty score $s(h)$ is mapped through a calibration function g that has been certified at population level, giving $\hat{c}(h) = g(s(h))$. The hypothesis passes if $\hat{c}(h) \geq \tau_r$. If it fails, the outcome is DEFER (Section 4.3).
- Gate 3, trajectory uncertainty**. The uncertainty propagated across the investigation so far, U_{traj} , must not exceed κ_r . If it does, the outcome is ESCALATE, because upstream steps may have contaminated the conclusion.

A **provenance veto** follows the gates. If the justification for a depends on untrusted, tainted inputs *and* a reaches an execution, egress or state-changing sink, the outcome is ESCALATE regardless of confidence. *Confidence cannot launder taint*: an attacker who can shape inputs can also shape the model’s apparent certainty.

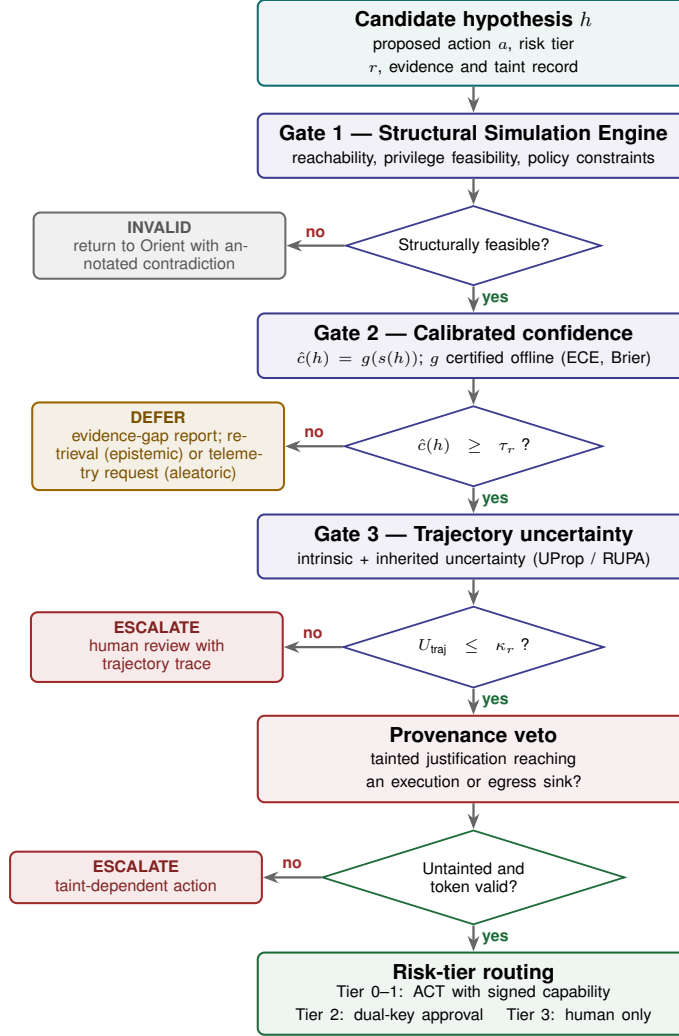


Figure 2: Decision gate logic. All checks run in deterministic code outside the LLM. A failure routes to INVALID (back to Orient), DEFER or ESCALATE. Thresholds τ_r and κ_r depend on the action’s risk tier r . Passing every gate makes an action *eligible* for autonomy only up to its tier.

Act — Bounded, Risk-Tiered Outcomes

Outcomes are limited to ACT, DEFER and ESCALATE. Autonomy is bounded by the reversibility and blast radius of the action (Table 5), not by confidence alone. An ACT requires a short-lived capability token, signed by the gate service, bound to the specific action, target and hypothesis identifier, and verified by the tool gateway. The LLM never holds such a token. This follows emerging guidance on agent identity and authorisation [39, 42]. Every input, hypothesis, score, gate result and approval is appended to a hash-chained, tamper-evident audit log.

Table 5: Action risk tiers. Thresholds tighten with tier; Tier 3 is never autonomous.

Tier	Examples	Reversibility	Authorisation if all gates pass
0	Enrichment, read-only queries, ticket annotation	No state change	ACT
1	Tagging, watch-listing, sandbox detonation, single-session token revocation	Fully reversible, local	ACT with signed capability
2	Host isolation, account disablement, firewall block	Reversible with business impact	ESCALATE: dual-key human approval with evidence and trajectory trace
3	Mass credential reset, production deletion, external notification	Hard or impossible to reverse	Human-only; agent may prepare but not execute

4.3 Formal Uncertainty Quantification

Version 1 applied ECE as a per-hypothesis gate. That is a category error. ECE and the Brier score are *population-level* statistics, computed over many predictions with known outcomes. They cannot be evaluated for a single, unresolved hypothesis. Version 2 therefore separates three levels (Figure 3).

Level 1 — per-hypothesis uncertainty and its decomposition. For each hypothesis-level question (for example, “is host X compromised via technique T ?”), we draw S samples from each of K scale-matched models. We cluster the answers by bidirectional entailment into meaning classes c [18], which gives per-model distributions $p_k(c | x)$ and the mixture $\bar{p}(c | x) = \frac{1}{K} \sum_k p_k(c | x)$. Following the standard ensemble decomposition [12, 31],

$$\underbrace{\mathcal{H}[\bar{p}(c | x)]}_{U_{\text{tot}}} = \underbrace{\frac{1}{K} \sum_k \mathcal{H}[p_k(c | x)]}_{U_{\text{ale}}} + \underbrace{\mathcal{I}(c; k | x)}_{U_{\text{epi}}}. \quad (1)$$

High U_{epi} (disagreement between models) triggers corrective retrieval, because more evidence can reduce it. High U_{ale} that persists after the retrieval budget is spent indicates that the telemetry itself is insufficient (dropped packets, missing logs, deliberate obfuscation). The outcome is then DEFER with a specific telemetry request. Single-model self-consistency is not enough, because a model can repeat the same error confidently [58]. Cross-model disagreement gives a better, though still imperfect, signal of epistemic uncertainty [63]. The raw score $s(h)$ used by Gate 2 can be U_{tot} , the probability mass of the supporting meaning class, or a learned combination with retrieval-quality features.

Level 2 — population-level calibration certification. A calibration map g is fitted, by temperature scaling, isotonic regression [20] or trajectory-feature calibration [67], on $\mathcal{D}_{\text{cal}}$: hypotheses from *closed* incidents whose outcomes are adjudicated. A deployment (a given model ensemble, prompts, retrieval corpus and g) is *certified* only if, on a held-out set $\mathcal{D}_{\text{val}}$,

$$\text{ECE} = \sum_{m=1}^M \frac{|B_m|}{n} |\text{acc}(B_m) - \text{conf}(B_m)| \leq \varepsilon_{\text{cal}}, \quad \text{BS} = \frac{1}{n} \sum_{i=1}^n (\hat{c}_i - y_i)^2, \quad (2)$$

with equal-mass bins B_m [37] and the Brier score [6] tracked alongside. We use $\varepsilon_{\text{cal}} = 0.15$ as an illustrative default carried over from Version 1. Operators should set it from risk appetite and the size of $\mathcal{D}_{\text{val}}$, and should report confidence intervals for ECE, which is biased for small samples. Calibration is recomputed on rolling windows as outcomes arrive. A significant rise in ECE or Brier score revokes certification, and Tier 1 autonomy falls back to ESCALATE until recalibration.

Per-decision gating. With a certified g , Gate 2 compares $\hat{c}(h)$ with a tier-specific threshold τ_r . Rather than fixing τ_r by hand, we choose it on $\mathcal{D}_{\text{cal}}$ so that the error rate among auto-accepted hypotheses (the *selective risk*) is at most a target α_r , with high probability. This uses distribution-free risk control [1]. The guarantee assumes exchangeability between calibration and deployment data, which drift violates. This is a further reason for rolling recertification.

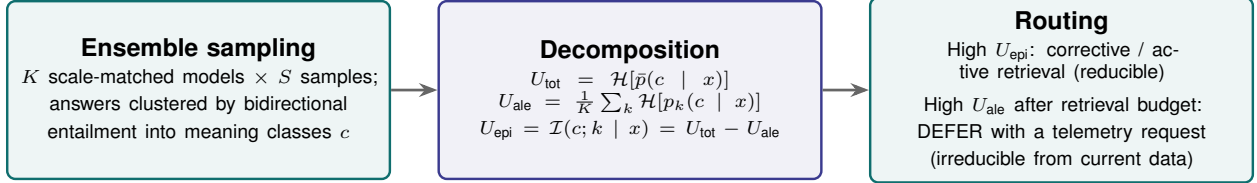
Level 3 — trajectory-level propagation. Investigations are multi-step: correlate, retrieve, hypothesise, validate, recommend. Following UProp [13], we write the uncertainty at step t as

$$U_t = U_t^{\text{int}} + U_t^{\text{ext}}, \quad (3)$$

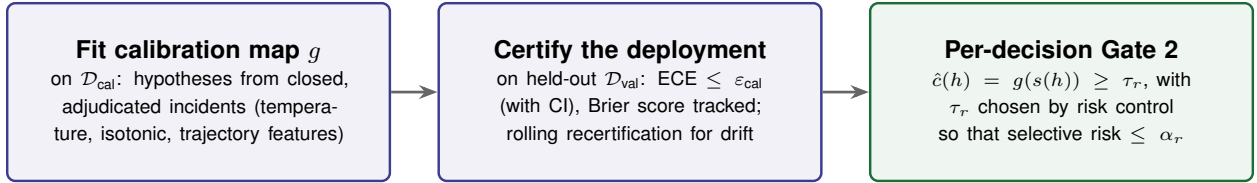
where U_t^{int} is the intrinsic uncertainty of the current step, estimated as in Level 1, and U_t^{ext} is the uncertainty inherited from earlier decisions, estimated as the mutual information between the current decision and the trajectory history using

trajectory-dependent sampling. (The notation is ours; see Duan et al. [13] for the estimator.) When steps branch and merge, as when parallel sub-agents query different data sources, graph-structured propagation over reasoning, tool and observation nodes is more appropriate [34]. Gate 3 requires $U_{\text{traj}} = U_T \leq \kappa_r$. Because uncertainty can vanish at agent hand-offs [14], every inter-agent message carries its sender’s uncertainty estimate and taint record as structured fields, not as prose.

LEVEL 1 — PER-HYPOTHESIS UNCERTAINTY (computed for every hypothesis)



LEVEL 2 — CALIBRATION: certified offline, applied per decision



LEVEL 3 — TRAJECTORY PROPAGATION (Gate 3)

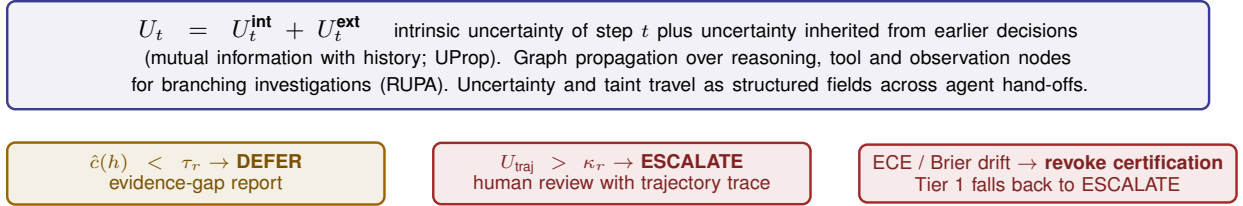


Figure 3: Uncertainty quantification in three levels. Level 1 decomposes per-hypothesis uncertainty and routes reducible (epistemic) uncertainty to retrieval and irreducible (aleatoric) uncertainty to DEFER. Level 2 certifies calibration at population level and applies a calibrated, risk-controlled threshold per decision. Level 3 propagates uncertainty along the investigation trajectory.

4.4 Zero-Trust Runtime Defenses

Four mechanisms implement the zero-trust runtime [28]. They are designed to be consistent with control-flow and data-flow separation [11]:

1. **Context as data.** CTI, alerts, logs and API responses are never parsed as instructions to the system. The LLM’s outputs are structured hypotheses consumed by deterministic code. They are never tool calls.
2. **Semantic firewall (auditor).** A pre-execution auditor checks proposed actions against the hypothesis schema, the action allow-list and the target scope. It also flags injection-like content. It complements, but does not replace, items 3 and 4.
3. **Capability tokens for tool invocation.** The tool gateway executes only actions that carry a valid, short-lived, signed token bound to action, target and hypothesis. Per-agent non-human identities prevent privilege inheritance (ASI03).
4. **Taint tracking.** Data lineage is tracked from ingestion to sink. Tainted justifications cannot authorise actions at execution, egress or state-changing sinks without human approval.

4.5 Proof-of-Concept Implementation

The proof of concept has five components: (1) a locally hosted LLM restricted to a structured hypothesis schema, with no tool access; (2) a CRAG-plus-FLARE retrieval pipeline with an evaluator agent; (3) an uncertainty agent that computes ensemble and semantic-disagreement scores and calls a rule-based SSE over a synthetic topology and identity graph; (4) a trajectory module that accumulates step-level uncertainty; and (5) a decision gate with audit logging. The proof of concept predates the Version 2 calibration design. Its Gate 2 thresholded raw uncertainty scores directly, without a certified calibration map or risk-controlled thresholds. Implementing Levels 2 and 3 as specified here is part of the evaluation protocol in Section 6.

5 Preliminary Results

Status of these results. The results below come from a small, single-author proof of concept run on static, synthetic alert and CTI scenarios (multi-stage intrusion, lateral movement, credential abuse). They show that the design is feasible and indicate effect direction. They are *not* benchmark results. The scenarios, the baseline and the labelling were not independently constructed, and no confidence intervals are reported. Version 1 compared these figures with industry-wide hallucination statistics. That comparison was not like-for-like and has been removed. All comparisons below are against an unconstrained baseline in which the same LLM was given the same scenarios without the framework.

Table 6: Preliminary proof-of-concept indicators (static synthetic scenarios; same LLM with and without the framework).

Indicator	Unconstrained baseline	Epistemic framework
Hallucinated reasoning (analyst-labelled)	12%	3%
Deferral rate (DEFER + ESCALATE)	5%	22%
Missing evidence explicitly surfaced	30%	85%
Structurally infeasible hypotheses reaching the analyst	not checked	0 (removed by SSE)

Qualitative observations. Evidence surfacing. The CRAG evaluator was the main driver of explicit missing-evidence reports. It flagged insufficient or contradictory retrieved context and triggered corrective retrieval before generation. **Structural contradictions.** The SSE removed hypotheses whose lateral-movement path required administrative access to segments marked air-gapped in the topology model. Without the SSE, the baseline presented these hypotheses fluently and without any sign of infeasibility. **Deferral as signal.** Each DEFER carried a structured evidence-gap report (what is missing, where it could be obtained, and which hypothesis it would discriminate). This turns “I don’t know” into a work item rather than a dead end.

The cost of deferral. A rise in deferral from 5% to 22% is a cost as well as a safeguard. Whether it is a net benefit depends on *deferral precision*, meaning the share of deferred cases that were genuinely ambiguous or would otherwise have produced an error, and on the analyst time each deferral consumes. The proof of concept measured neither. Both are primary outcomes in the evaluation protocol below.

6 Evaluation Protocol for Independent Validation

To make the framework’s claims falsifiable, we specify the evaluation that a full study should report:

1. **Data.** Public, realistic SOC datasets (for example, LANL authentication data as used by AgentSOC [53], Splunk Boss-of-the-SOC, and OTRF Security-Datasets), plus held-out synthetic multi-stage scenarios with ground-truth attack graphs. Report the number of scenarios, hypotheses and decisions.
2. **Models.** Exact model identifiers and versions, decoding parameters, ensemble composition (K , S), prompts and retrieval corpus snapshot.
3. **Labelling.** At least two independent analysts label hallucinated reasoning against ground truth using a written rubric. Report inter-rater agreement (Cohen’s or Fleiss’ κ) and adjudication rules.
4. **Calibration metrics.** ECE with equal-mass bins and bootstrap intervals; Brier score with its reliability and resolution components; AUROC of $s(h)$ for error detection; risk–coverage curves for Gate 2.
5. **Operational metrics.** Deferral rate, deferral precision, escalation precision, analyst minutes per incident, time-to-containment, and end-to-end latency.
6. **Security metrics.** Attack success rate under AgentDojo-style injections placed in telemetry [10], including adaptive attacks [38], measured separately for exfiltration, unauthorised action and suppression of true detections.

7. **Ablations.** Each gate, the taint veto and the retrieval components removed one at a time. Trajectory gating compared against a step-level-only baseline.
8. **Drift.** Recertification behaviour across at least one model-version change and one retrieval-corpus refresh.

7 Discussion

7.1 Implications for SOC Operations and KPIs

Throughput KPIs (alerts closed per hour, mean time to close) push analysts toward accepting confident AI conclusions, which is the mechanism behind ASI09. Under this framework, the KPIs that matter are deferral precision, escalation precision, false-containment rate, time-to-containment for true positives, and analyst time per deferred case. Treating “I don’t know” as a first-class outcome is useful only if those deferrals are precise and actionable. The structured evidence-gap report exists to make them so. The SANS data on low workflow integration [55] and rising concern about hallucination [54] suggest that SOC leaders already sense this gap but lack the metrics to manage it.

The adversarial dimension reinforces the point. When KPIs reward throughput, pressure to override a DEFER is greatest exactly when an injected narrative sounds most authoritative. Requiring dual-key approval for Tier 2 actions, and the taint veto, make overrides deliberate and attributable instead of impossible. Humans keep final authority, but exercising it leaves a record.

7.2 Governance Alignment and the “Right to Act”

Earlier ethical frameworks framed oversight as *meaningful human control* [52], a requirement that proved hard to implement technically. The ACT/DEFER/ESCALATE architecture implements a more concrete notion: an agent *earns* the right to act within a bounded scope by demonstrating, through recorded evidence, that it is calibrated, structurally consistent and acting on trusted provenance.

ISO/IEC 42001 and NIST. ISO/IEC 42001 specifies an AI management system with lifecycle, impact-assessment and data controls [26]. It does not prescribe specific technical mechanisms such as ECE thresholds, cryptographic audit trails or particular threat models. We present the framework’s mechanisms as *evidence-producing design choices* that support conformity, not as requirements of the standard. Continuous recertification produces lifecycle-monitoring evidence. Tier and dual-key records document human oversight. The hash-chained audit log supports traceability of individual decisions. The same artefacts support the NIST AI RMF [40] and its emerging cybersecurity profile, which identifies AI agents as a distinct use archetype [41]. They also align with NIST’s agent-standards and agent-identity work [39, 42].

EU. The EU AI Act (Regulation (EU) 2024/1689) [16] was amended by the Digital Omnibus on AI (Regulation (EU) 2026/1744) [17], which defers Annex III high-risk obligations to December 2027. An internal SOC triage agent is generally not an Annex III system. For most SOC deployments, the Act’s relevance is therefore indirect: it shapes expectations for logging, transparency and human oversight rather than imposing direct obligations.

India. The *India AI Governance Guidelines* (MeitY, November 2025) are voluntary. They emphasise human oversight and propose a national AI-incident database [35]. CERT-In’s advisory CIAD-2026-0020, *Defending against Frontier AI-Driven Cyber Risks* (April 2026), warns that frontier AI is lowering the barrier to sophisticated intrusion [7]. Its subsequent blueprint CISO-2026-02 (May 2026) recommends patching known-exploited vulnerabilities on internet-facing systems within 12 hours where feasible, and keeping inventories of AI systems and integrations [8]. For Indian SOC’s, the framework’s audit trail provides the decision-level record that post-incident reporting and AI-inventory governance require.

7.3 Limitations and Future Work

Evidence base. The proof of concept is small, synthetic and single-author (Section 5). The evaluation protocol in Section 6 is the priority for future work.

Ground-truth delay and label quality. Calibration needs adjudicated outcomes, which can lag by days and are themselves noisy, as the HLE audits show [66]. Future work should study delayed-label and proxy-label calibration and quantify how sensitive certification is to label noise.

Distribution shift. Risk-controlled thresholds assume exchangeability [1]. Campaign-driven shifts violate it, so adaptive thresholds and shift detection are needed.

Adversarial manipulation of uncertainty. An attacker who shapes inputs can also shape model agreement and apparent confidence. The taint veto limits the damage to sinks, but uncertainty estimators should themselves be red-teamed under adaptive attack [38].

Cost and latency. Ensemble sampling and trajectory propagation multiply inference cost. Cheaper estimators, such as single-model probes calibrated against the ensemble, are an open direction.

Scope of SSE. Structural validation can only be as accurate as the topology and identity graphs, which drift in real environments.

Volatile external figures. Leaderboard values and several 2026 industry statistics change quickly or come from vendor reports. We give access dates and treat them as context, not as precise baselines.

8 Conclusion

Between Version 1 and Version 2 of this paper, the risks it anticipated became documented incidents. Zero-click prompt injection, MCP supply-chain command injection and in-the-wild exploitation of AI gateways share one root cause: agents that let untrusted context drive action, and that express confidence they have not earned. Calibration data from frontier models show that capability gains do not automatically bring calibration gains.

The Epistemic Decision Quality Framework responds with controls rather than more autonomy. LLMs only generate competing hypotheses. Provenance and taint bound what any hypothesis can authorise. Structural validation removes impossible narratives. Population-level calibration certification, per-decision risk-controlled thresholds and trajectory-level propagation decide when the system has earned the right to act. Risk tiers, dual-key approvals and a tamper-evident audit trail keep that right bounded and accountable. Our preliminary results suggest the trade-off is favourable: fewer hallucinated conclusions in exchange for more, better-documented deferrals. That trade-off still has to be demonstrated under the evaluation protocol we specify.

The question is no longer whether AI can act at machine speed. It is whether the enterprise has built the structural, statistical and governance scaffolding needed to know when it should not.

A Changes from Version 1

- **Statistics replaced:** vendor and secondary-site figures (100,000 alerts per day, 70% abandoned, 94%/92% AI adoption and trust, 15–52% hallucination, “up to 99%” code hallucination) are replaced with SANS 2026, ISC2 2025, Verizon DBIR 2026 and primary research.
- **Workforce gap:** 4.8 million is now attributed to ISC2 2024. The ISC2 2025 study published no gap estimate.
- **Calibration metric:** HLE figures are now correctly labelled as RMS calibration error and updated to the October 2026 full leaderboard.
- **UQ design:** ECE and Brier score moved from per-hypothesis gates to population-level certification. Per-decision gating now uses calibrated confidence with risk-controlled thresholds. The aleatoric/epistemic decomposition is stated formally.
- **New sections:** threat model; 2025–2026 incident analysis; OWASP Agentic Top 10 mapping; action risk tiers and provenance veto; evaluation protocol.
- **Proof of concept:** compared against the internal unconstrained baseline rather than industry statistics; self-citation removed; results labelled preliminary.
- **Citations corrected:** AgentSOC (Roy and Singh), Agentic AI attack surface (Jiang et al.), Agentic Confidence Calibration (Zhang et al.), UQ in LLM agents (Oh et al.), HLE-Verified (Zhai et al.), Steyvers et al. (*Nature Machine Intelligence*, 2025), UProp (Duan et al.), OWASP LLM09 (now Misinformation).

References

- [1] A. N. Angelopoulos, S. Bates, A. Fisch, L. Lei, and T. Schuster. Conformal risk control. *arXiv:2208.02814*, 2022.
- [2] Anthropic. Disrupting the first reported AI-orchestrated cyber espionage campaign. Threat intelligence report, November 2025. <https://www.anthropic.com/news/disrupting-AI-espionage>.
- [3] L. Beurer-Kellner et al. Design patterns for securing LLM agents against prompt injections. *arXiv:2506.08837*, 2025.
- [4] BleepingComputer. Anthropic claims of Claude AI-automated cyberattacks met with doubt. November 2025.
- [5] J. R. Boyd. *A Discourse on Winning and Losing*. Unpublished briefing slides, Maxwell AFB, 1987.
- [6] G. W. Brier. Verification of forecasts expressed in terms of probability. *Monthly Weather Review*, 78(1):1–3, 1950.

- [7] CERT-In. Defending against frontier AI-driven cyber risks. Advisory CIAD-2026-0020, 26 April 2026.
- [8] CERT-In. Blueprint for reducing exposure and defending against AI-assisted vulnerabilities exploitation in digital infrastructure. Guideline CISG-2026-02, May 2026.
- [9] Cyata Security. Vulnerabilities in the official Git MCP server (CVE-2025-68143, CVE-2025-68144, CVE-2025-68145). Security advisory, January 2026.
- [10] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *NeurIPS Datasets and Benchmarks Track*, 2024. arXiv:2406.13352.
- [11] E. Debenedetti, I. Shumailov, T. Fan, J. Hayes, N. Carlini, D. Fabian, C. Kern, C. Shi, A. Terzis, and F. Tramèr. Defeating prompt injections by design. *arXiv:2503.18813*, 2025.
- [12] S. Depeweg, J. M. Hernández-Lobato, F. Doshi-Velez, and S. Udluft. Decomposition of uncertainty in Bayesian deep learning for efficient and risk-sensitive learning. In *ICML*, 2018.
- [13] J. Duan, J. Diffenderfer, S. Madireddy, T. Chen, B. Kailkhura, and K. Xu. UProp: Investigating the uncertainty propagation of LLMs in multi-step agentic decision-making. *arXiv:2506.17419*, 2025.
- [14] C. Emde, A. Goel, S. Yun, S. J. Oh, and M. Gubri. Lost in communication: Uncertainty propagation in multi-agent systems. In *ICML*, 2026.
- [15] Epoch AI. Humanity’s Last Exam: benchmark review. <https://epoch.ai/benchmarks/hle/review>, accessed October 2026.
- [16] European Parliament and Council. Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act). *Official Journal of the European Union*, 2024.
- [17] European Parliament and Council. Regulation (EU) 2026/1744 amending Regulation (EU) 2024/1689 (Digital Omnibus on AI). *Official Journal of the European Union*, July 2026.
- [18] S. Farquhar, J. Kossen, L. Kuhn, and Y. Gal. Detecting hallucinations in large language models using semantic entropy. *Nature*, 630:625–630, 2024.
- [19] FutureHouse. About 30% of Humanity’s Last Exam chemistry/biology answers are likely wrong. Blog post, 23 July 2025.
- [20] C. Guo, G. Pleiss, Y. Sun, and K. Q. Weinberger. On calibration of modern neural networks. In *ICML*, 2017.
- [21] A. R. Hevner, S. T. March, J. Park, and S. Ram. Design science in information systems research. *MIS Quarterly*, 28(1):75–105, 2004.
- [22] HUMAN Security. The 2026 State of AI Traffic & Cyberthreat Benchmark Report. March 2026.
- [23] IBM Security and Ponemon Institute. Cost of a Data Breach Report 2026. 2026.
- [24] ISC2. 2024 ISC2 Cybersecurity Workforce Study. 2024.
- [25] ISC2. 2025 ISC2 Cybersecurity Workforce Study. December 2025. <https://www.isc2.org/Insights/2025/12/2025-ISC2-Cybersecurity-Workforce-Study>.
- [26] ISO/IEC. ISO/IEC 42001:2023 — Information technology — Artificial intelligence — Management system. 2023.
- [27] Z. Jiang, F. F. Xu, L. Gao, Z. Sun, Q. Liu, J. Dwivedi-Yu, Y. Yang, J. Callan, and G. Neubig. Active retrieval augmented generation. In *EMNLP*, 2023. arXiv:2305.06983.
- [28] X. Jiang, S. Yang, W. Yang, Y. Liu, and C. Ji. Agentic AI as a cybersecurity attack surface: Threats, exploits, and defenses in runtime supply chains. *arXiv:2602.19555*, 2026.
- [29] A. T. Kalai, O. Nachum, S. S. Vempala, and E. Zhang. Why language models hallucinate. *arXiv:2509.04664*, 2025.
- [30] A. Kendall and Y. Gal. What uncertainties do we need in Bayesian deep learning for computer vision? In *NeurIPS*, 2017.
- [31] B. Lakshminarayanan, A. Pritzel, and C. Blundell. Simple and scalable predictive uncertainty estimation using deep ensembles. In *NeurIPS*, 2017.
- [32] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W. Yih, T. Rocktäschel, S. Riedel, and D. Kiela. Retrieval-augmented generation for knowledge-intensive NLP tasks. In *NeurIPS*, 2020.
- [33] N. F. Liu, K. Lin, J. Hewitt, A. Paranjape, M. Bevilacqua, F. Petroni, and P. Liang. Lost in the middle: How language models use long contexts. *Transactions of the ACL*, 12:157–173, 2024.
- [34] Z. Ma, B. Cao, Y. Lu, H. Lin, and X. Han. From sequence to structure: Relational uncertainty propagation for LLM agents. *arXiv:2608.16002*, 2026.
- [35] Ministry of Electronics and Information Technology, Government of India. India AI Governance Guidelines. November 2025.
- [36] Meta AI. Agents rule of two: A practical approach to AI agent security. Blog post, 31 October 2025.
- [37] M. P. Naeini, G. F. Cooper, and M. Hauskrecht. Obtaining well calibrated probabilities using Bayesian binning. In *AAAI*, 2015.

- [38] M. Nasr, N. Carlini, C. Sitawarin, S. V. Schulhoff, J. Hayes, M. Ilie, J. Pluto, S. Song, H. Chaudhari, I. Shumailov, A. Thakurta, K. Y. Xiao, A. Terzis, and F. Tramèr. The attacker moves second: Stronger adaptive attacks bypass defenses against LLM jailbreaks and prompt injections. *arXiv:2510.09023*, 2025. USENIX Security 2026.
- [39] NIST National Cybersecurity Center of Excellence. Accelerating the adoption of software and AI agent identity and authorization. Concept paper, February 2026.
- [40] NIST. Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100-1, 2023.
- [41] NIST. Cybersecurity framework profile for artificial intelligence (Cyber AI Profile). NIST IR 8596, initial preliminary draft, December 2025.
- [42] NIST Center for AI Standards and Innovation. AI Agent Standards Initiative. February 2026.
- [43] Noma Security. ForcedLeak: AI agent risks exposed in Salesforce Agentforce. Security research, 25 September 2025.
- [44] C. Oh, S. Park, T. E. Kim, J. Li, W. Li, S. Yeh, X. Du, H. Hassani, P. Bogdan, D. Song, and S. Li. Uncertainty quantification in LLM agents: Foundations, emerging challenges, and opportunities. *arXiv:2602.05073*, 2026.
- [45] OWASP GenAI Security Project. OWASP Top 10 for Agentic Applications (2026 edition). December 2025.
- [46] OWASP GenAI Security Project. OWASP Top 10 for LLM Applications 2025. 2024.
- [47] OX Security. MCP STDIO command injection: Full vulnerability advisory. 15 April 2026.
- [48] R. Parasuraman and D. H. Manzey. Complacency and bias in human use of automation: An attentional integration. *Human Factors*, 52(3):381–410, 2010.
- [49] L. Phan et al. Humanity’s Last Exam. *arXiv:2501.14249*, 2025.
- [50] J. Reason. *Human Error*. Cambridge University Press, 1990.
- [51] P. Reddy and A. S. Gujral. EchoLeak: The first real-world zero-click prompt injection exploit in a production LLM system. *arXiv:2509.10540*, 2025.
- [52] H. M. Roff and R. Moyes. Meaningful human control, artificial intelligence and autonomous weapons. Briefing paper, Article 36, 2016.
- [53] J. Roy and S. K. Singh. AgentSOC: A multi-layer agentic AI framework for security operations automation. In *IEEE 5th International Conference on AI in Cybersecurity (ICAIC)*, 2026. *arXiv:2604.20134*.
- [54] SANS Institute. 2026 SANS AI Survey. July 2026.
- [55] SANS Institute. 2026 SANS SOC Survey. 2026.
- [56] Scale AI. Humanity’s Last Exam leaderboard. https://labs.scale.com/leaderboard/humanitys_last_exam, accessed October 2026.
- [57] A. Singh, A. Ehtesham, S. Kumar, T. Talaei Khoei, and A. V. Vasilakos. Agentic retrieval-augmented generation: A survey on agentic RAG. *arXiv:2501.09136*, 2025.
- [58] J. Spracklen, R. Wijewickrama, A. H. M. N. Sakib, A. Maiti, B. Viswanath, and M. Jadliwala. We have a package for you! A comprehensive analysis of package hallucinations by code generating LLMs. In *USENIX Security Symposium*, 2025.
- [59] M. Steyvers, H. Tejada, A. Kumar, C. Belem, S. Karny, X. Hu, L. W. Mayer, and P. Smyth. What large language models know and what people think they know. *Nature Machine Intelligence*, 7(2):221–231, 2025.
- [60] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas. MITRE ATT&CK: Design and philosophy. Technical report, The MITRE Corporation, 2018.
- [61] Vectara. Hallucination leaderboard (HHEM-2.3). <https://github.com/vectara/hallucination-leaderboard>, accessed October 2026.
- [62] Verizon. 2026 Data Breach Investigations Report. May 2026.
- [63] L. Wimmer, Y. Sale, P. Hofman, B. Bischl, and E. Hüllermeier. Quantifying aleatoric and epistemic uncertainty in machine learning: Are conditional entropy and mutual information appropriate measures? In *UAI*, 2023.
- [64] Wiz Threat Research. Attacks on AI infrastructure: 90-day honeypot telemetry. 2026. <https://www.wiz.io/blog/ai-infrastructure-honeypot>.
- [65] S.-Q. Yan, J.-C. Gu, Y. Zhu, and Z.-H. Ling. Corrective retrieval augmented generation. *arXiv:2401.15884*, 2024.
- [66] W. Zhai et al. HLE-Verified: A systematic verification and structured revision of Humanity’s Last Exam. *arXiv:2602.13964*, 2026.
- [67] J. Zhang, C. Xiong, and C.-S. Wu. Agentic confidence calibration. *arXiv:2601.15778*, 2026.
- [68] Q. Zhao, D. Li, Y. Liu, W. Cheng, Y. Sun, M. Oishi, T. Osaki, K. Matsuda, H. Yao, C. Zhao, H. Chen, and X. Zhao. Uncertainty propagation on LLM agent. In *ACL*, 2025.
- [69] A. Zou, M. Lin, E. Jones, M. Nowak, M. Dziemian, et al. Security challenges in AI agent deployment: Insights from a large scale public competition. *arXiv:2507.20526*, 2025.

This preprint is intended to contribute to ongoing research on trustworthy AI and security automation. Feedback, critique and collaboration are welcome.

Author contact: drupad.h.sachania@live.com